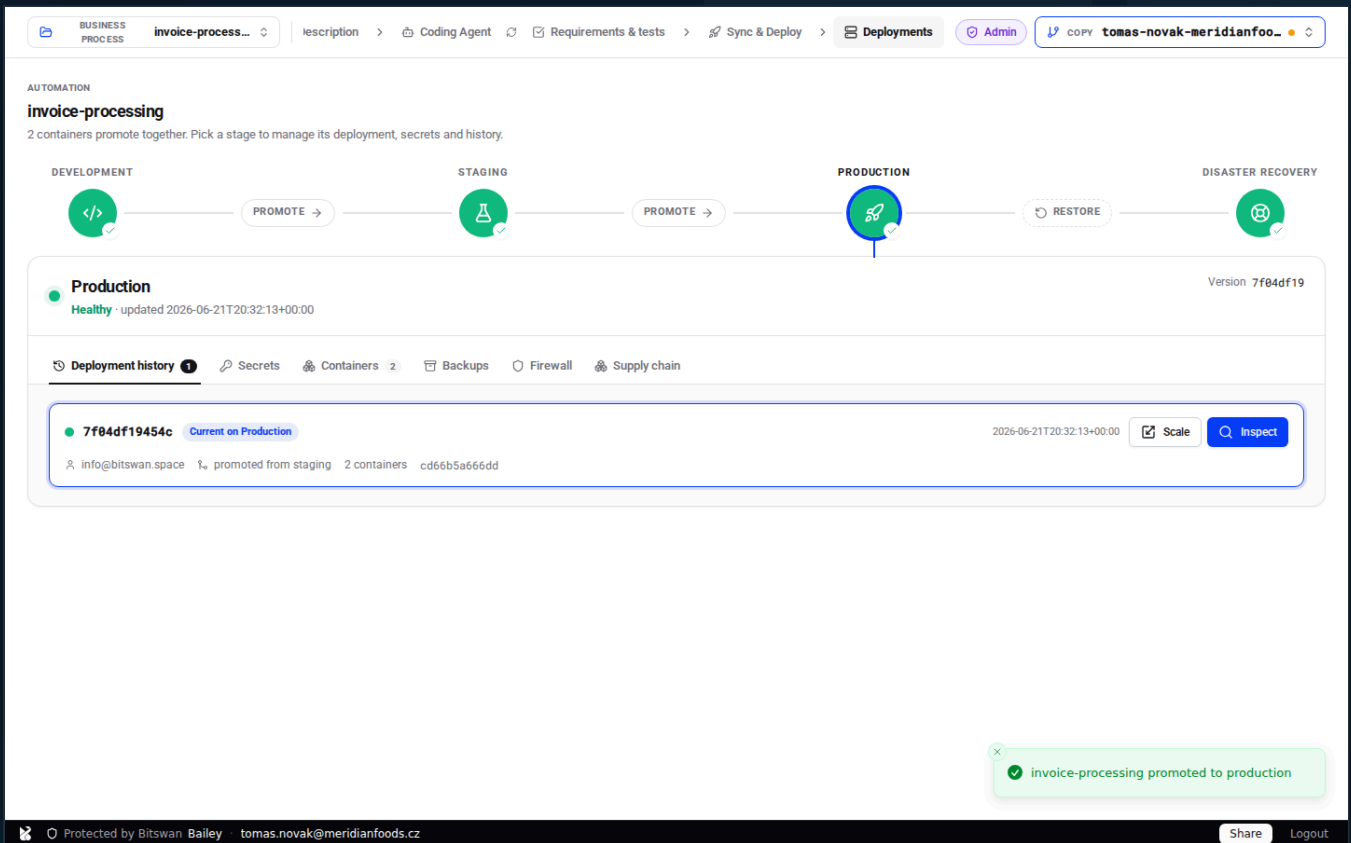


Run it like it matters.

Business processes on infrastructure that defends itself.

Staged deployment. One-click disaster-recovery rehearsals. Supply-chain scanning before anything ships. A GDPR record of processing that writes itself. Access control an auditor will actually like. This is the platform — and this manual, printed straight from a live system.

Bailey is **best practice**.



The screenshot displays the BitSwan Bailey interface for managing the 'invoice-processing' automation. The top navigation bar includes tabs for 'BUSINESS PROCESS', 'Description', 'Coding Agent', 'Requirements & tests', 'Sync & Deploy', 'Deployments', 'Admin', and a user profile 'tomas-novak-meridianfoo...'. The main content area shows a workflow diagram with stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The 'PRODUCTION' stage is currently selected and highlighted. Below the diagram, the 'Production' status is shown as 'Healthy' with a timestamp 'updated 2026-06-21T20:32:13+00:00' and version '7f04df19'. A 'Deployment history' section lists the current deployment '7f04df19454c' as 'Current on Production', with details like 'info@bitswan.space', 'promoted from staging', '2 containers', and 'cd66b5a666dd'. A 'Scale' button and an 'Inspect' button are also visible. A green notification box at the bottom right states 'invoice-processing promoted to production'. The footer includes a copyright notice 'Protected by BitSwan Bailey tomas.novak@meridianfoods.cz', a 'Share' button, and a 'Logout' link.

- Every screenshot in this manual was captured live, walking the real product on 2026-06-21.

CONTENTS

The Operator's Handbook

·	Why teams put Bitswan in front of what matters	4
---	--	---

THE WALKTHROUGH

CH 01	Claim & device trust — Get in safely	5
-------	--	---

CH 02	Workspaces — Draw the boundary	8
-------	--------------------------------------	---

CH 03	Server overview & endpoints — See the estate	11
-------	--	----

CH 04	Your devices — Manage your hardware	14
-------	---	----

CH 05	The workspace & copies — Work in the open	17
-------	---	----

CH 06	Business processes — Define the work	20
-------	--	----

CH 07	Describe the process — Say what it does	23
-------	---	----

CH 08	Coding Agent & requirements — Build it	25
-------	--	----

CH 09	Sync & Deploy — Ship changes	28
-------	------------------------------------	----

CH 10	Supply chain — Know your ingredients	33
-------	--	----

CH 11	Blue-green production — Promote with confidence	35
-------	---	----

CH 12	Containers — See what's running	38
-------	---------------------------------------	----

CH 13	Secrets — Keep secrets secret	40
CH 14	Backups & retention — Capture the truth	43
CH 15	Rehearse & restore (DR) — Sleep at night	45
CH 16	Deployment history & inspect — Show your work	49
CH 17	Firewall & data processing — Control the edges	52
CH 18	People & roles — Right people, right rights	55
 COMPLIANCE REFERENCE		
REF	Standards → features	58
REF	What Bailey gives you — at a glance	65
REF	ISO/IEC 27001:2022	67
REF	SOC 2 (Trust Services Criteria)	70
REF	DORA (Regulation (EU) 2022/2554)	72
REF	NIS2 (Directive (EU) 2022/2555)	74
REF	GDPR (Regulation (EU) 2016/679)	76

WHY TEAMS PUT BITSWAN IN FRONT OF WHAT MATTERS

01 Ship without holding your breath

Promote dev → staging → production across three blue-green slots over two persistent databases. The live slot never blinks; the standby is always one cutover away.

02 Rehearse the disaster before it happens

Restore any production backup into an isolated DR slot, verify it by hand, mark it recovery-tested, then swap it live with a single ingress cutover. No data move. No downtime.

03 Know what's inside before it runs

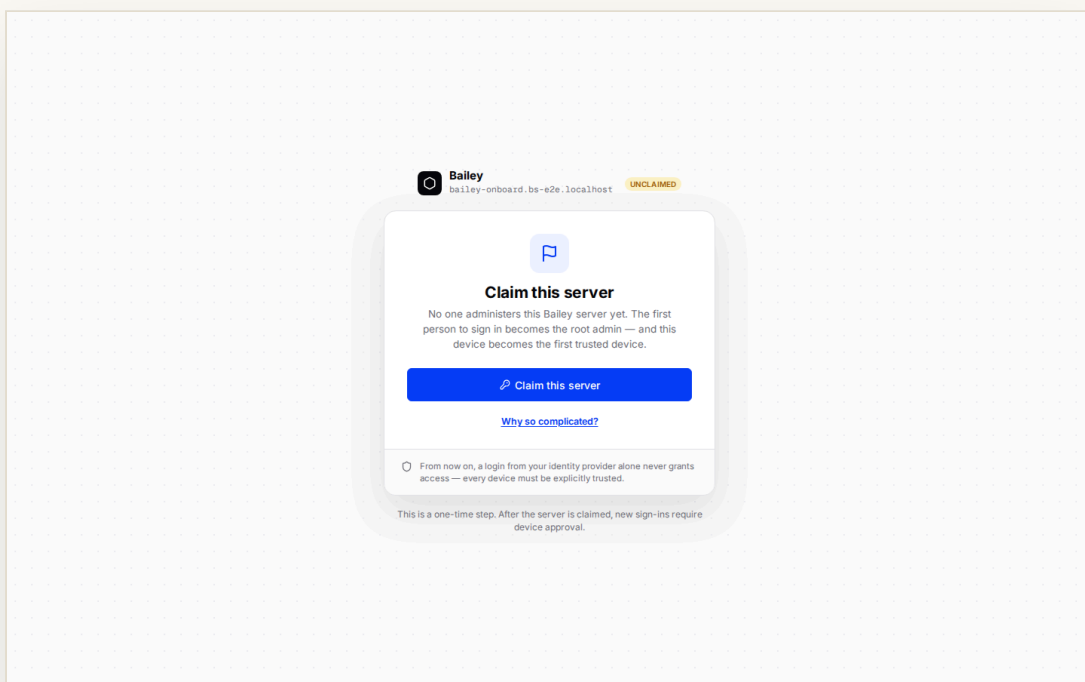
Every image is scanned for CVEs before deploy. Waivers live in your source tree, not buried in config. Auditors get a clean, signed story.

04 Trust the device, not just the password

The first operator claims the server; every device after is approved. Identity is enforced at the gate — your processes run safely behind it.

Claim & device trust

The first operator claims the server and becomes root admin. Their device becomes the first trusted device — and every device after is approved, not assumed.



Bailey onboarding · signed in, about to claim the server

A password that leaks shouldn't be the end of the story. Bailey binds access to **trusted devices**: Tomáš Novák signs in through your identity provider, claims the Meridian Foods server, and the browser he claimed from is enrolled as the first trusted device — its cookie now proves the hardware, not just the credential.

From then on a new device must be **approved by someone who already holds one**: it shows a six-digit code and waits, and a trusted operator links it from *Your devices* → *Link a device*. The gate sits in front of everything — the console and every workspace app run behind it.

HOW TO

- 1 Sign in at the onboarding host.
- 2 Click **Claim this server** — you become root admin and this device is trusted.
- 3 A new device shows a code and waits for approval.
- 4 Approve it from a trusted device, or revoke it from **People & roles**.

WHY IT MATTERS

Identity is enforced once, at the gate. Your business processes never have to reinvent authentication — and a stolen password alone never reaches them.



Bailey is best practice — what the standards ask of you, and how this does it

NIS2

ART. 21(2)(J)

Multi-factor authentication & secured

access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.

SOC 2

CC6.1

Logical access security.

The gate authenticates and authorizes every request before it reaches a workspace app.

ISO/IEC 27001

A.5.15 / A.8.5

Access control & secure authentication.

Access is granted per identity and per device, and centrally revocable.

DORA

ART. 9(3)

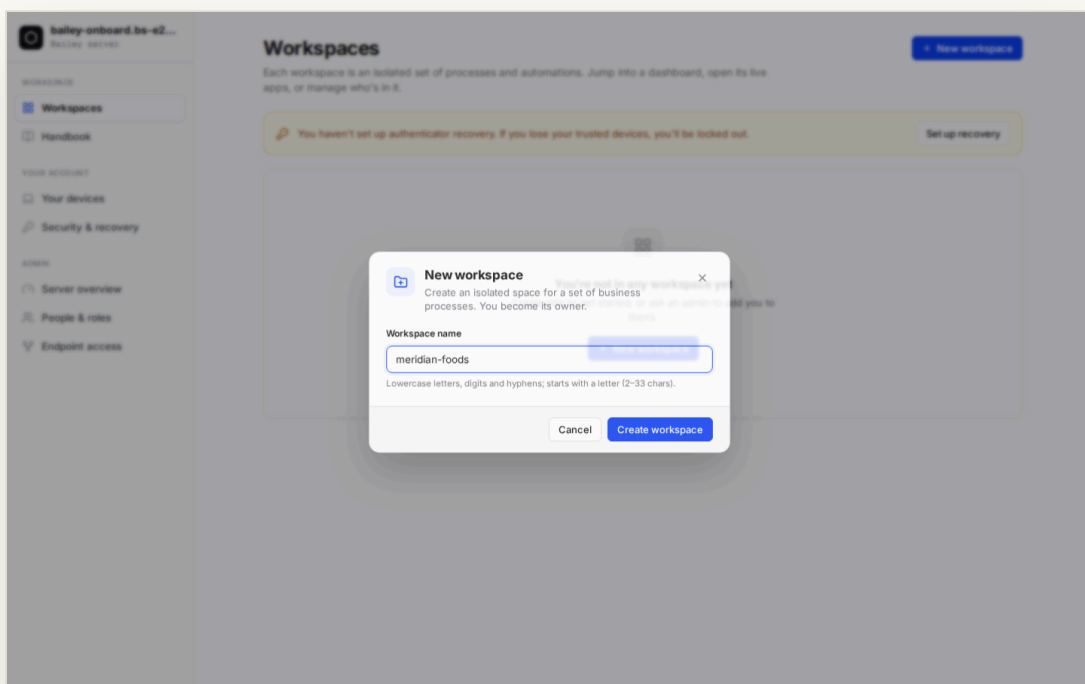
Strong authentication mechanisms.

Protection of ICT systems requires robust access control — the gate provides it uniformly.



Workspaces

A workspace is the access-control boundary — an isolated tenancy with an explicit owner and members. Who can see and do what is decided per workspace.



Server Console · the Workspaces view with the Meridian Foods workspace

From the Bailey Server Console, Tomáš creates the **Meridian Foods** workspace and becomes its owner. Creation is a live, streamed operation — you watch gitops, ingress and the dashboard come up before the workspace appears with an *Open* button.

A workspace is a blast radius for **access**: its own processes, its own data, and its own roster. Only the

people granted into it — at the role you give them — can reach its apps. (Promoting code through dev → staging → production happens *inside* a process; that's the stages, not the workspace — see Ch 09.)

HOW TO

- 1 Open **Workspaces** in the console.
- 2 Click **New workspace**, name it (lowercase, hyphenated) — you're the owner.
- 3 Watch it provision; press **Open** to enter its dashboard.
- 4 Invite members at the role they need.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.3 / A.5.15

Information access restriction & access

control. A workspace scopes who can reach its processes and data; access is granted per workspace.

SOC 2

CC6.3

Role-based access. Membership and roles are assigned per workspace and enforced server-side.

NIS2

ART. 21(2)(I)

Asset management & access control. Every workspace and its endpoints are inventoried and owned.

Server overview & endpoints

Before you build, know what you're running. The console's overview and endpoint pages inventory every workspace, route and protected endpoint on the server.

The screenshot displays the 'Server overview' page in the 'bailey-onboard.bs-e2e...' console. The left sidebar contains navigation links for 'Workspaces', 'Handbook', 'Your account', 'Your devices', 'Security & recovery', 'Server overview' (selected), 'People & roles', and 'Endpoint access'. The main content area shows the server's status as 'ONLINE' and provides a summary of resources: 0 workspaces, 1 person, 1 device, and 0 pending items. Below this, a table lists server details for 'bailey-onboard.bs-e2e.localhost', including region, version, claimed by, claimed time, and uptime. A 'System resources' section shows memory (12% used), disk (29% used), and CPU (43% used) usage. A 'Recent security activity' section lists two events related to device approval and server claiming. At the bottom, a 'SIEM forwarding' section shows a 'DISCONNECTED' status. A notification banner at the bottom right states 'Workspace "meridian-foods" created'.

Server Console · the server overview

The **Server overview** is the operator's situational awareness: how many workspaces, how many trusted devices, the health of the platform's own services. **Endpoint access** lists every protected hostname the gate fronts — workspace dashboards, gitops, automation frontends — each

with its owner and the workspace it belongs to.

This is your live asset register. When an auditor asks “what is exposed, and who owns it?”, the answer is a page, not an afternoon.

HOW TO

- 1 Open **Server overview** for platform health and counts.
- 2 Open **Endpoint access** to see every protected route.
- 3 Confirm each endpoint has the right owner and workspace.

Endpoint access

Every endpoint this server routes and who can reach it.

This list is read-only — it's here for auditing, not for changing access. Bailey follows the principle of **least privilege**: each endpoint's owner manages who can reach it, from that endpoint's own share dialog. There is deliberately **no god-mode admin** who can grant themselves into everything — removing that single point of compromise reduces risk and makes the server easier to keep compliant.

PUBLIC ENDPOINTS

- bailey-onboard.bs-e2e.localhost** [↗](#)
Public — any signed-in user reaches this without a per-endpoint grant. It's how a new device gets trusted (the onboarding flow).

WORKSPACES & APPS

- meridian-foods-dashboard.bs-e2e.localhost** [↗](#) WORKSPACE
tomas.novak@meridianfoods.cz OWNER
No additional grants — only the owner has access.
- meridian-foods-gitops.bs-e2e.localhost** [↗](#) SERVICE
tomas.novak@meridianfoods.cz OWNER
No additional grants — only the owner has access.

Workspace "meridian-foods" created

Server Console · endpoint access — every protected route and its owner



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.9

Inventory of information and other associated assets. Every workspace and protected endpoint is enumerated from real, live state.

NIS2

ART. 21(2)(I)

Asset management. The estate of exposed services is inventoried with ownership.

SOC 2

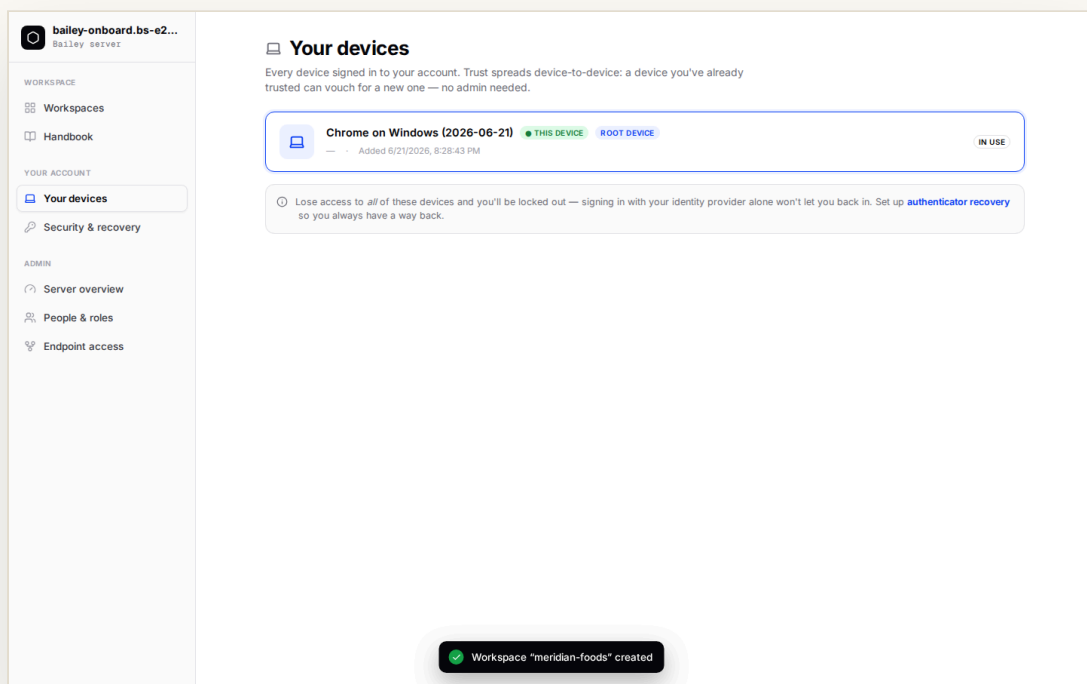
CC6.1

Logical access security. Each endpoint sits behind the gate with an explicit owner.



Your devices

Every browser that reaches the platform is a named, trusted device you can see, label and revoke. Lose a laptop and you cut its access everywhere, instantly.



Server Console · Your devices — trusted hardware, with the root device badged

The **Your devices** page lists the hardware tied to your identity: the *Root device* that claimed the server, any *Admin-approved* or *Linked* devices, which one is in use right now. This is also where you **Link a device** — type the six-digit code a new browser is showing and it's let in.

De-provisioning is a click: sign a device out and its cookie is revoked across the whole platform. No password reset cascade, no orphaned sessions.

HOW TO

- 1 Open **Your devices** in the console.
- 2 Review trusted devices and their badges.
- 3 To admit a new browser, enter its code under **Link a device**.
- 4 Sign out a lost device to revoke it everywhere.



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2

CC6.2 / CC6.3

Access provisioning & de-provisioning.

Devices are granted and revoked centrally and immediately.

ISO/IEC 27001

A.5.15 / A.8.1

Access control & user-endpoint devices.

Trusted devices are enrolled, labelled and revocable.

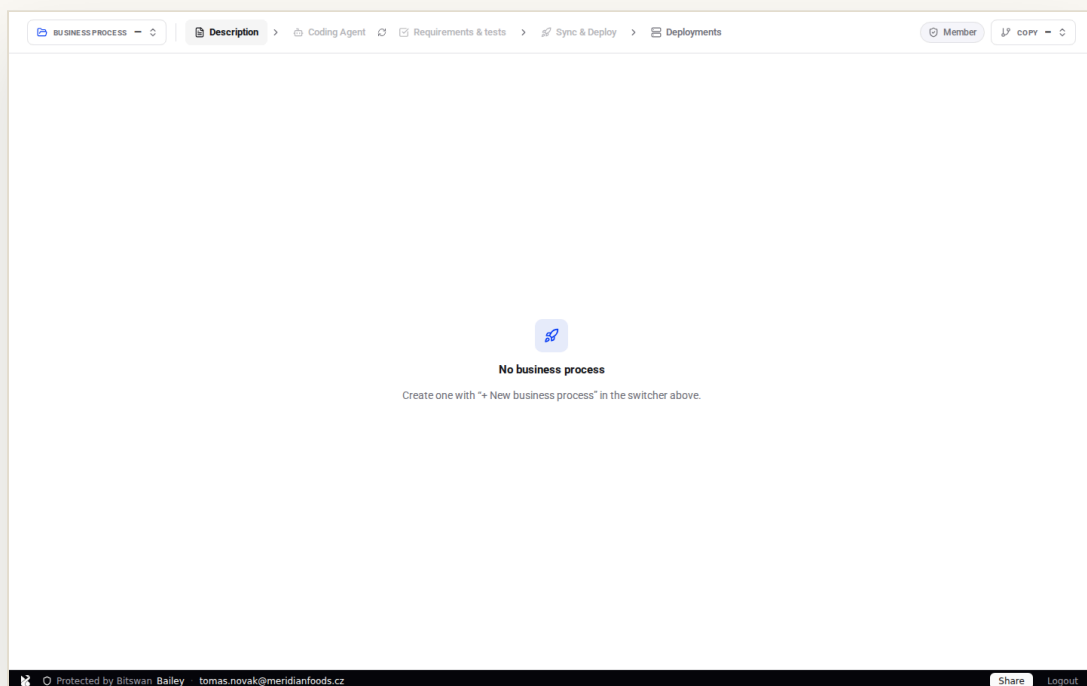
NIS2

ART. 21(2)(J)

Secured access. Hardware-bound trust is enrolled and managed per person.

The workspace & copies

Open a workspace and you land in its dashboard, working in your own personal copy — an isolated branch where nothing you do touches main until you choose to.



Workspace dashboard · the business-process shell, your personal copy active

Every operator gets a **personal copy** of the workspace — auto-created and auto-selected the moment you open the dashboard. It's your private branch: edit, build and preview without disturbing anyone else's work or the live *main*.

The **copy switcher** (top-right) shows which copy is active, whether it's synced with main, and lets you spin up a *New copy*. Promotion of your

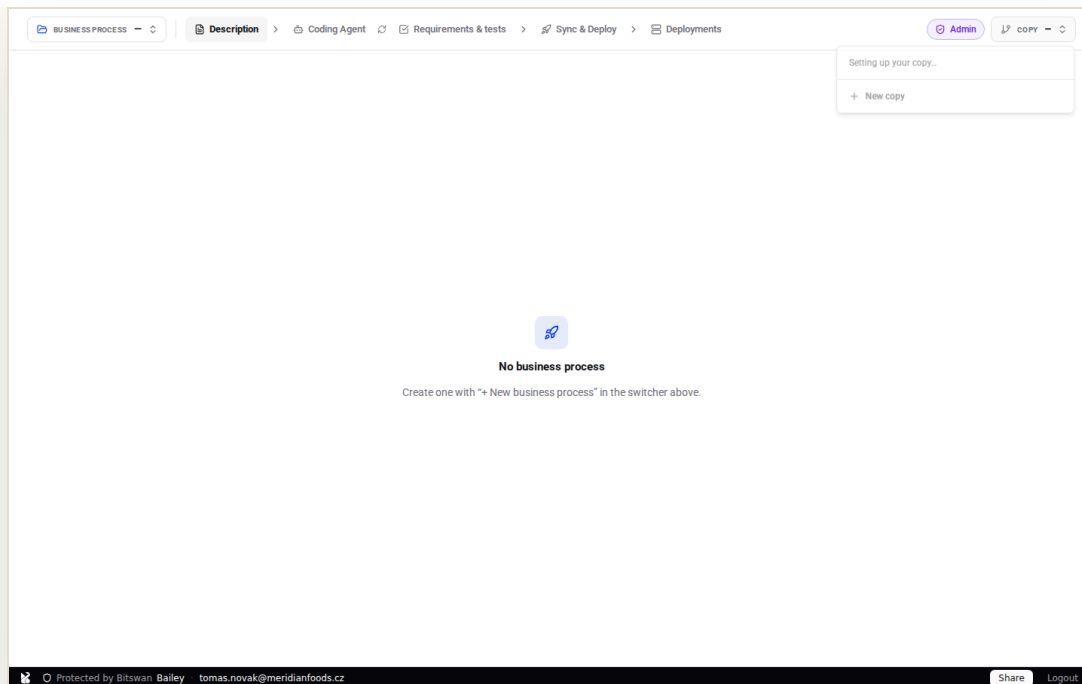
work into main happens deliberately, through Sync & Deploy (Ch 08) — never by accident.

HOW TO

- 1 Press **Open** on the workspace to enter its dashboard.
- 2 Your personal copy is selected automatically.
- 3 Use the **copy switcher** to see sync state or start a new copy.
- 4 Everything you build stays in your copy until you Sync & Deploy.

WHY IT MATTERS

Isolated copies are environment separation by default: experimentation never risks the shared main, and every change reaches production only through a reviewed, deliberate path.



Copy switcher · your copy, its sync state, and “New copy”



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.31

Separation of development, test and

production. A personal copy isolates work-in-progress from main and from deployed stages.

SOC 2

CC8.1

Change management. Changes originate in an isolated copy and reach main only through Sync & Deploy.

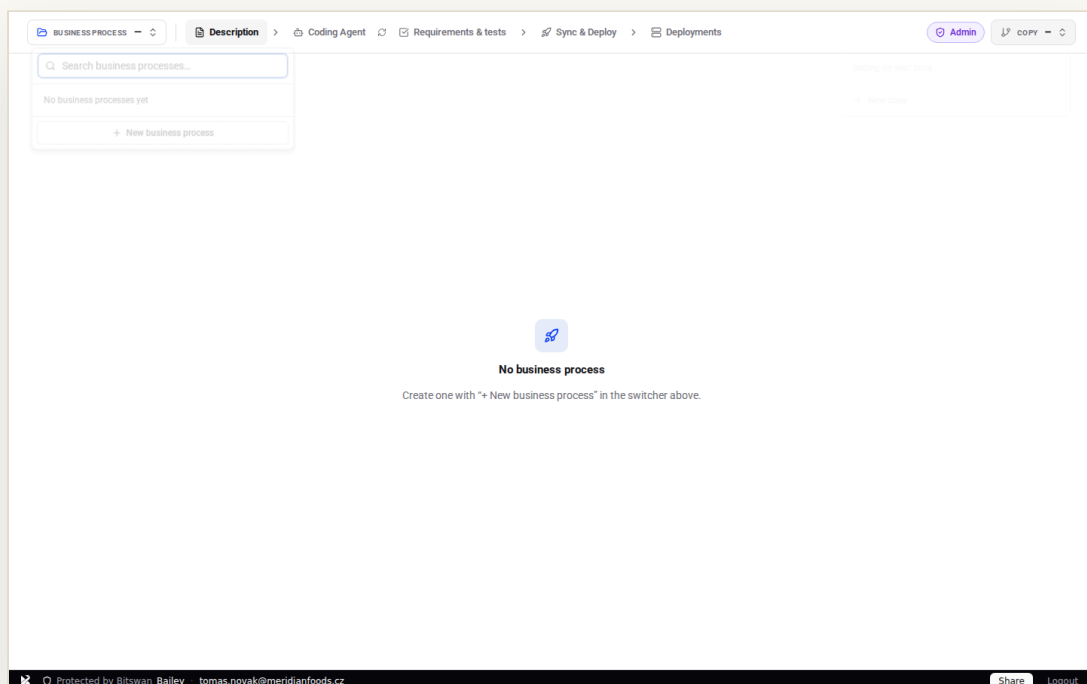


BitSwan Bailey · The Operator's Handbook

The workspace & copies — 05

Business processes

A business process is the unit you build, ship and operate. Create one, and the workspace scaffolds its automations ready to fill in.



Business-process switcher · select or create a process

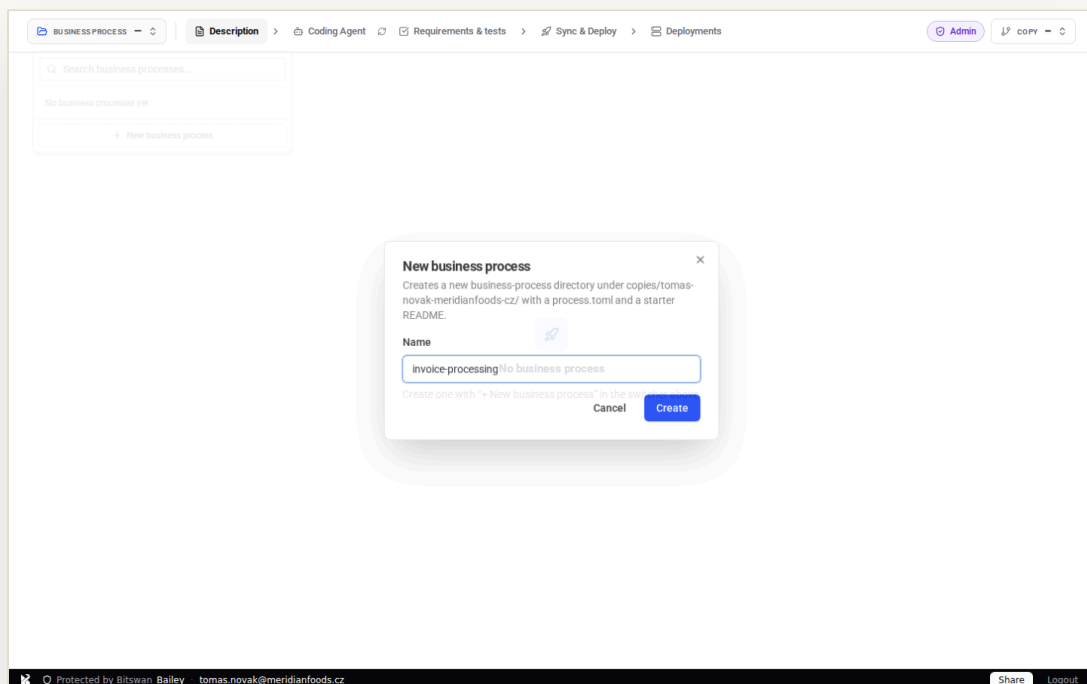
Meridian's accounts-payable lives in one business process: **invoice-processing**. The **New business process** modal takes a name (lowercase, hyphenated) and scaffolds its automations — a backend and a frontend — so there's something real to describe, build and deploy.

The process is the boundary for everything that follows: its

description, its code, its CVE checks, its stages, its secrets, its backups and its firewall are all scoped to it.

HOW TO

- 1 Open the **business-process switcher** (top-left).
- 2 Click **New business process**.
- 3 Name it in the modal; press **Create**.
- 4 The process is scaffolded and selected.



New business process · naming the invoice-processing process



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.9

Inventory of assets. Each business process is a named, owned unit of the estate.

ISO/IEC 27001

A.8.25

Secure development lifecycle. Work is organised per process, with its own pipeline and controls.



Describe the process

Before code, intent. Each business process carries a living specification — what it does, for whom, and the rules it must keep.

invoice-processing saved
Describe your business process

1. Approve — beginning over — **Approval** is held for a human, the next auto approval.

2. 1. ****Post**** — approved invoices post to the ledger and the vendor is paid via the gateway.

3. **The flow**

3. mermaid auto

4. flowchart TD

5. A[Vendor invoice
PDF / EDI] --> B{Valid?
totals + VAT vs PO}

6. B -- No --> R[Reject and notify vendor]

7. B -- Yes --> C{Amount > 5000 EUR?}

8. C -- Yes --> H[Hold for approval]

9. C -- No --> D[Post to ledger]

10. H --> D

11. D --> P[Pay via gateway]

Rules it must keep

- VAT total must match the purchase order within €0.01.
- Invoices over €5,000 require human approval before posting.
- A duplicate invoice number must never post twice.

ATTACHMENTS
No attachments yet — drop files here or click Upload. The coding agent sees them under attachments/.

Building image for backend: Step 1/11 : FROM golang:1.23-alpine

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz Share Logout

Invoice Processing · the README, with a Mermaid flowchart of the invoice lifecycle

Marek documents the **Invoice Processing** spec right in the dashboard: ingest vendor invoices, validate totals and VAT against the PO, route anything over €5,000 for approval, post the rest to the ledger. The editor is rich text with Markdown shortcuts and renders fenced mermaid blocks as diagrams.

The description versions *with* the process — documentation that lives next to the code, not in a wiki that drifts. Ctrl+S saves; the indicator confirms it.

HOW TO

- 1 Open the **Description** tab.
- 2 Write the spec; use a mermaid block for the flow.
- 3 Press **Ctrl+S** — it versions with the process.



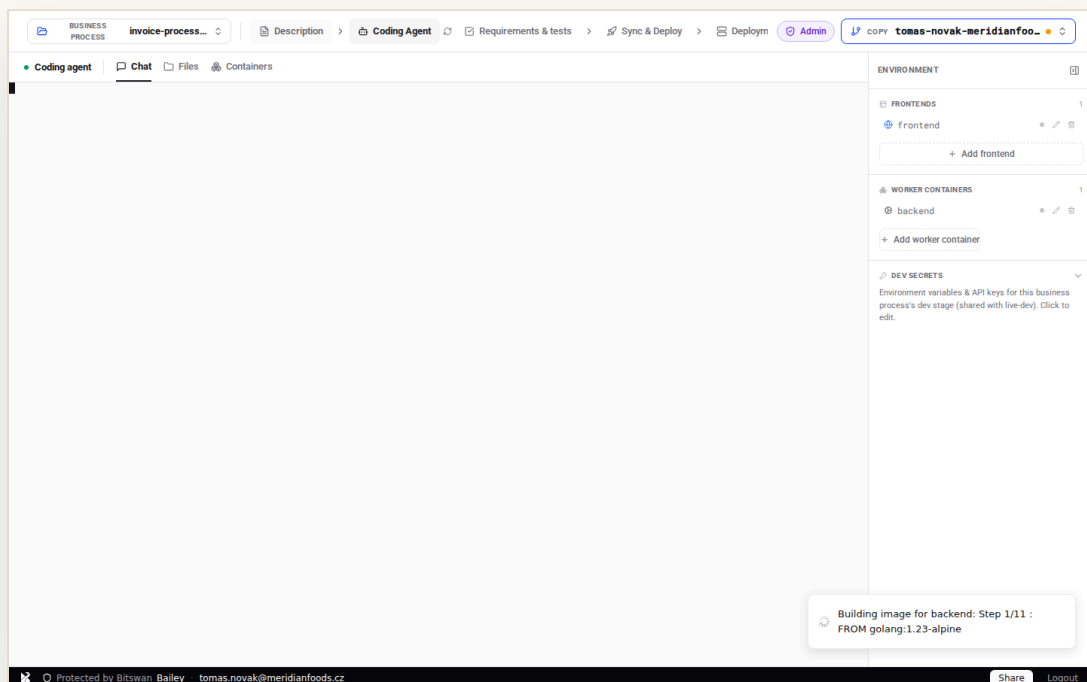
Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.5.37

Documented operating procedures. The process and its rules are written down and kept current alongside the code.

Coding Agent & requirements

Describe the process, then let a coding agent build it — inside the workspace’s isolated sandbox — and pin the rules it must keep as runnable requirements.



Coding Agent · building the invoice flow inside the workspace

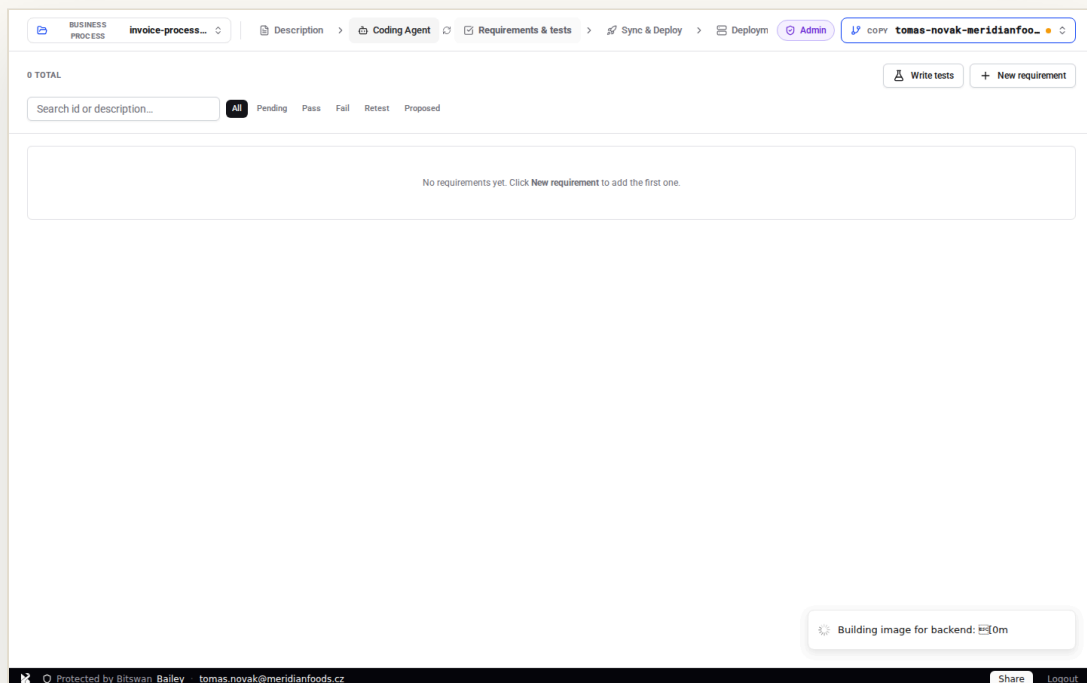
The **Coding Agent** works straight from your specification: a terminal and a file tree right in the workspace, writing the invoice-processing automation in your isolated copy you review before it ever reaches main. The point isn't that there's an agent — it's **where** it runs. The agent runs *inside* Bailey, not beside it: it can only

reach hosts the firewall allows, sees only the secrets you've granted, and everything it produces still passes Sync & Deploy and the CVE checks before it ships.

The **Requirements & tests** tab turns the spec's rules into runnable checks — VAT matches the PO, invoices over €5,000 are held, duplicate invoice numbers never post twice — so “does it still do what we promised?” is a button, not a meeting.

HOW TO

- 1 Open the **Coding Agent** tab; start a session against your copy.
- 2 It builds the automation from the Description.
- 3 Open **Requirements & tests**; record the rules as runnable specs.
- 4 Review the diff, then **Sync & Deploy**.



Requirements & tests · the rules the process must keep, as runnable specs



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.25 / A.8.31

Secure development lifecycle & environment separation. The agent builds in an isolated copy/sandbox, never touching production directly.

NIS2

ART. 21(2)(E)

Security in development. Agent output is CVE-scanned and reviewed before deploy.

SOC 2

CC6.6

Boundary protection. The agent's egress is constrained by the workspace firewall allow-list.

DORA

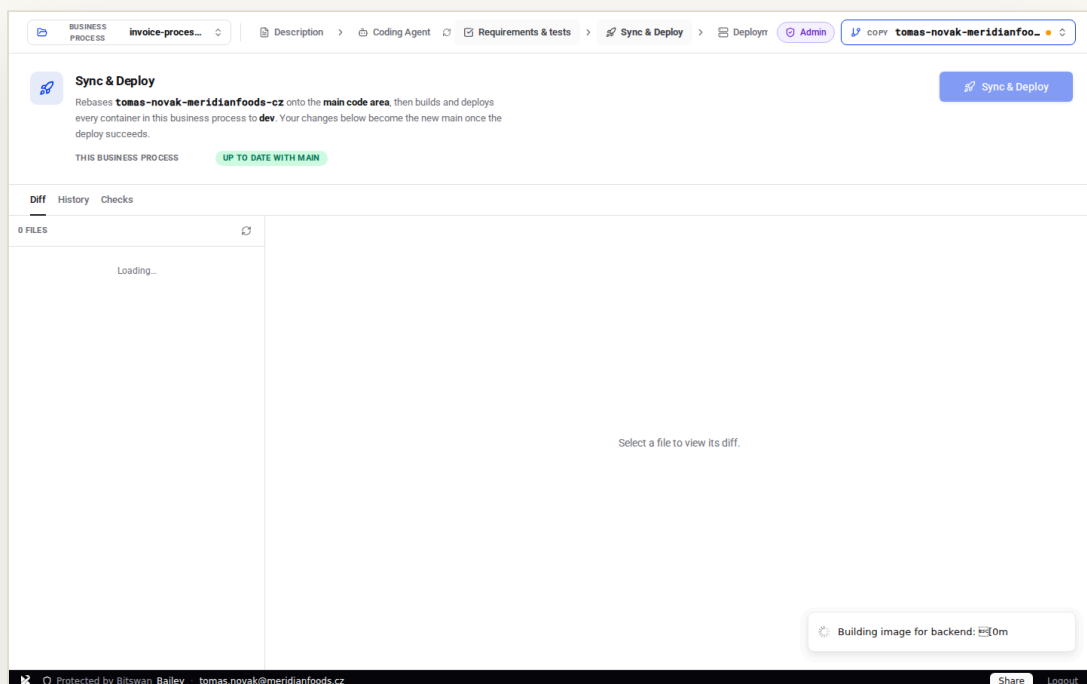
ART. 24–26

Resilience testing. Requirements are runnable specifications, re-run on demand.



Sync & Deploy

From a working copy to a healthy deployment — with the diff, the history and a security check standing between you and production.



Sync & Deploy · ready to ship invoice-processing to development

One button does the careful thing: commit work-in-progress, rebase your copy onto main, fast-forward, and roll out to development — **tracking the single deploy it started** rather than racing a second one. While it works, the button reads *Working...* and the live deploy step streams into a toast.

Around the button are the three things you check before shipping: the **Diff** (exactly what becomes main),

the **History** (your copy's and main's commits, with deploy markers), and the **Checks** tab — the precise CVEs of the image this deploy *would* build. Click any CVE for its advisory; record what's out of scope into your source tree, where review can see it.

HOW TO

- 1 Open **Sync & Deploy**.
- 2 Review the **Diff**, the **History**, and the **Checks** tab.
- 3 Press **Sync & Deploy** — dev goes **Healthy**.
- 4 Promote when you're ready.

WHY IT MATTERS

The check happens on the image that will actually run — not last week's scan. Security is a step in the flow, not a gate someone forgets.

Sync & Deploy

Rebases **tomas-novak-meridianfoods-cz** onto the **main code area**, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS **1 1 ahead** 37 uncommitted files · +1935 · -0

Diff History Checks

37 FILES

- added invoice-processing/README.md
- added invoice-processing/backend/auth.go
- added invoice-processing/backend/automation.toml
- added invoice-processing/backend/db.go
- added invoice-processing/backend/go.mod
- added invoice-processing/backend/go.sum
- added invoice-processing/backend/handlers_internal.go
- added invoice-processing/backend/handlers_public.go
- added invoice-processing/backend/image/Dockerfile
- added invoice-processing/backend/image/air.toml
- added invoice-processing/backend/image/entrypoint.sh

Select a file to view its diff.

Building image for backend: 100%

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz

Diff sub-tab · the files that become the new main

Sync & Deploy

Rebases **tomas-novak-meridianfoods-cz** onto the **main code area**, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS **1 1 ahead** 37 uncommitted files · +1935 · -0

Diff History Checks

117 TOMAS-NOVAK-MERIDIANFOODS-CZ
gitops@bitswan.local · 6/21/2026, 8:29:49 PM

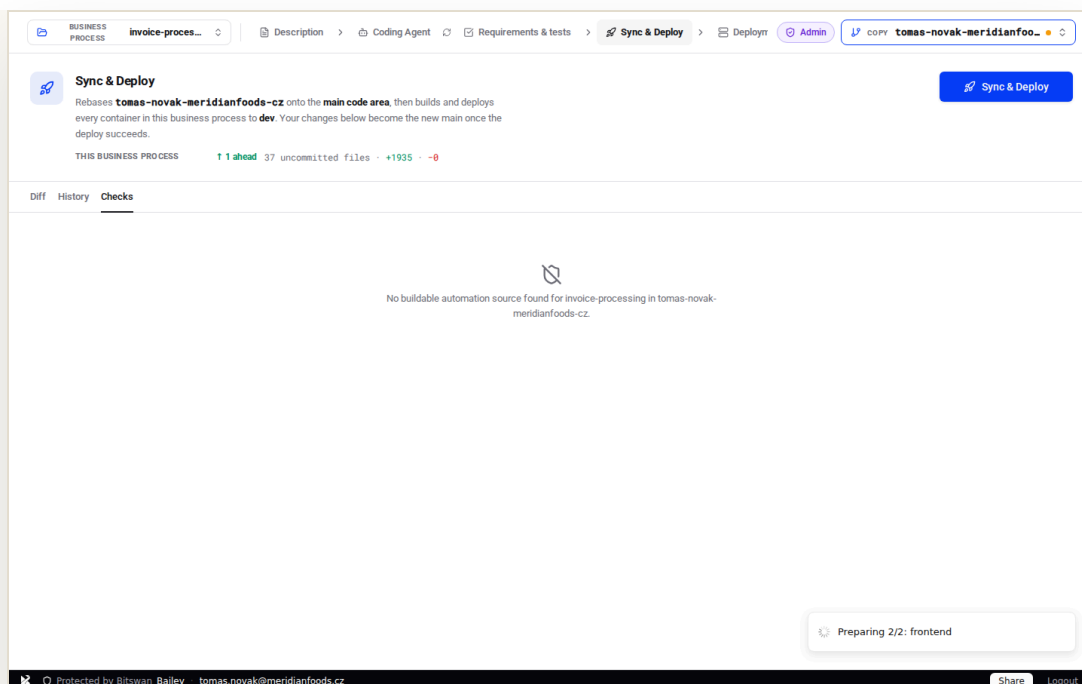
MAIN fdb4eb0 Initial commit
workspace@bitswan.local · 6/21/2026, 8:28:44 PM

Select a file to view its diff.

Building image for backend: 100%

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz

History sub-tab · copy + main commits with deploy markers



Checks sub-tab · CVEs of the image this deploy would build



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.8

Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.

NIS2

ART. 21(2)(E)

Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.

DORA

ART. 8–9

ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.

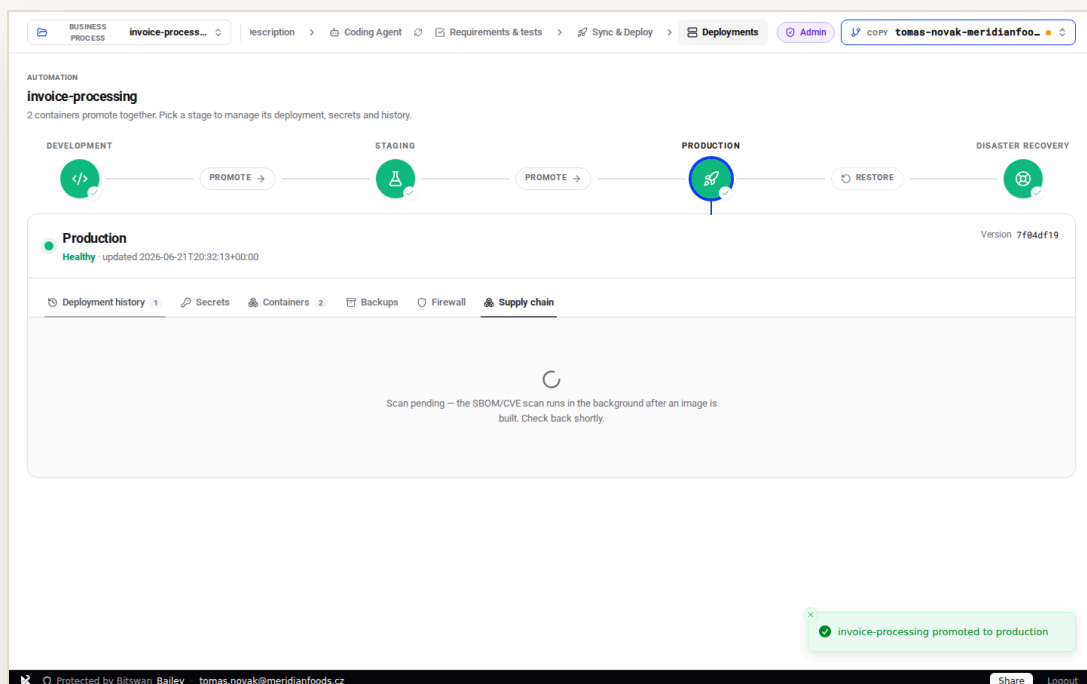
SOC 2

CC8.1

Change management. Commit, rebase, deploy is one controlled, observable operation.

Supply chain

A full software bill of materials for what you run — vulnerabilities ranked, advisories one click away, accepted risks recorded.



Supply chain · the SBOM/CVE panel for the deployed image

Every deployed image carries an SBOM. The **Supply chain** view ranks vulnerabilities by severity and shows the affected package; opening a CVE links straight to osv.dev, NVD and GitHub advisories so triage starts with the facts.

Out-of-scope decisions are explicit, attributable and stored in source — not a screenshot in someone's inbox. The scan runs on the image that

actually ships, so the picture is never stale.

HOW TO

- 1 Open a stage → **Supply chain.**
- 2 Sort by severity; open a CVE for its advisory.
- 3 Record any out-of-scope decision in-tree.



Bailey is best practice — what the standards ask of you, and how this does it

NIS2

ART. 21(2)(D)

Supply-chain security. You can produce, on demand, exactly what is inside what you run.

SOC 2

CC7.1

Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.

ISO/IEC 27001

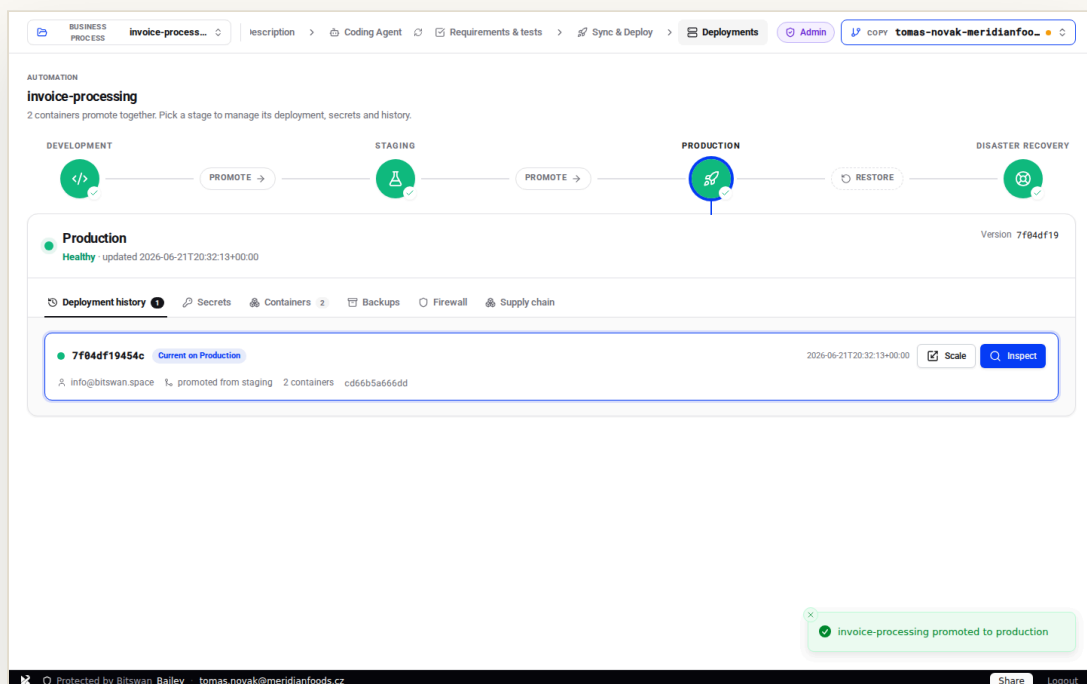
A.5.7 / A.8.8

Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.



Blue-green production

Three app slots over two persistent databases. The live slot owns production; the standby owns DR; the third is your zero-downtime buffer.



Deployments · Production Healthy after promote, every stage green

Promote dev → staging → production and the idle slot comes up on the live database, ingress repoints, the old slot retires. Promotion re-deploys the source stage's recorded image verbatim — what reaches production is exactly what you tested, even if the workspace source has moved on. Users never see a gap.

Production is a state you can read at a glance: which slot is live, which is standby, what's **Healthy**, and the version each stage is current on.

HOW TO

- 1 Open **Deployments** → **Development**.
- 2 Press **Promote** to staging, then to production.
- 3 Watch each stage report **Healthy** on screen.
- 4 Confirm Production shows the version you shipped.

3 slots

a / b / c app slots

2 DBs

persistent, slot-aware

0 s

downtime on promote



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.32

Change management. Production changes follow a controlled, reversible promotion path.

ISO/IEC 27001

A.8.31

Separation of development, test and production. The dev / staging / production stages keep environments cleanly separated within a process.

DORA

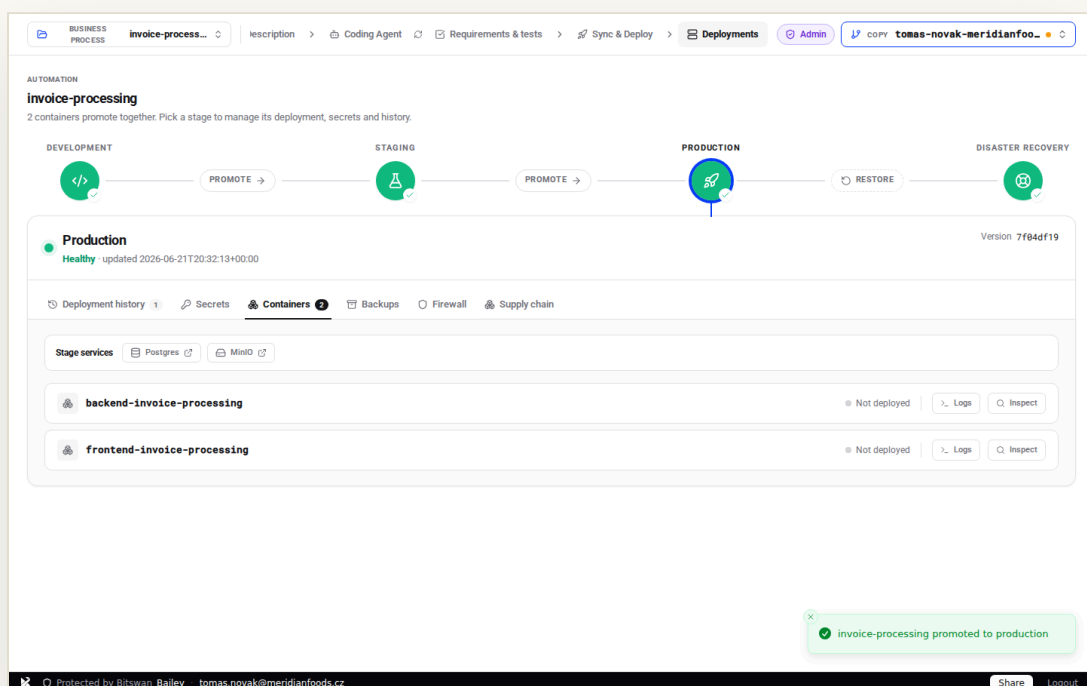
ART. 9

Protection & prevention. Minimise the impact of changes on the availability of critical functions.



Containers

The live container roster for a stage — every service of the deployment, its health, and per-container Logs, Inspect, and start/stop controls.



Production · the live containers of the current deployment

The **Containers** section is the operator's ground truth for a stage: each member of the deployment as a real running container, with its status. Open *Logs* to read what it's doing, *Inspect* for its configuration, or restart/stop a single service without touching the rest.

On Disaster Recovery, each container resolves to the standby

slot's own instance — so you operate the recovered app, not the live one.

HOW TO

- 1 Open a stage → **Containers**.
- 2 Read status per service.
- 3 Use **Logs / Inspect** to investigate.
- 4 Restart or stop a single container if needed.



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2
CC7.2

System monitoring. Container health is visible per service, per stage.

DORA
ART. 10

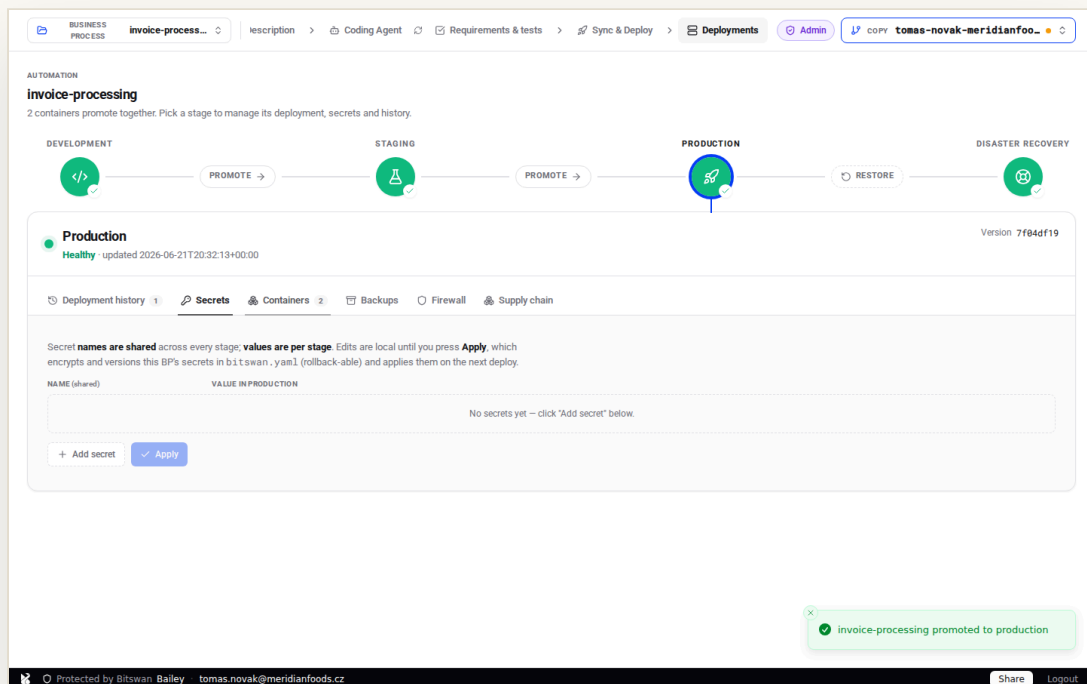
Detection. Operators can observe the live state of every running service.

ISO/IEC 27001
A.8.16

Monitoring activities. The running estate is observable in real time.

Secrets

Per-stage environment secrets, write-gated by role, injected at deploy and snapshotted with every deployment.



Production · environment secrets, role-gated

The payment-gateway credentials and the approval threshold live as **stage secrets**: shared names, per-stage values. Members read; admins and auditors write. You add a key and value right in the dashboard, and it's injected on the next deploy of that stage — never written into the repo.

Every deployment captures the secret set in force at that moment, so an Inspect of any historical deploy shows exactly which secrets it ran with. No

secrets in the repo, no secrets in a chat thread.

HOW TO

- 1 Open a stage → **Secrets**.
- 2 Add keys (gateway id, threshold...) with their values.
- 3 They're injected at deploy, never committed.
- 4 Each deploy snapshots the secret set in force.

The screenshot shows the BitSwan Bailey deployment interface for a business process named 'invoice-processing'. The interface displays a deployment pipeline with stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The 'PRODUCTION' stage is currently selected. Below the pipeline, the 'Secrets' tab is active, showing a table for secrets. A warning message states: '1 secret has no value in Production yet.' The table has two columns: 'NAME (shared)' and 'VALUE IN PRODUCTION'. One secret, 'GOPAY_CLIENT_ID', is listed with the value 'Needs a value' and a 'NOT SET' status. At the bottom, there is a green notification box that says 'invoice-processing promoted to production'.

BUSINESS PROCESS: invoice-process... | Description | Coding Agent | Requirements & tests | Sync & Deploy | Deployments | Admin | COPY tomas-novak-meridianfoo...

AUTOMATION
invoice-processing
2 containers promote together. Pick a stage to manage its deployment, secrets and history.

DEVELOPMENT — PROMOTE —> STAGING — PROMOTE —> PRODUCTION — RESTORE — DISASTER RECOVERY

Production
Healthy updated 2026-06-21T20:32:13+00:00 Version 7f04df19

Deployment history 1 | Secrets | Containers 2 | Backups | Firewall | Supply chain

Secret names are shared across every stage; values are per stage. Edits are local until you press **Apply**, which encrypts and versions this BP's secrets in `bitswan.yaml` (rollback-able) and applies them on the next deploy.

⚠ 1 secret has no value in Production yet.

NAME (shared)	VALUE IN PRODUCTION
GOPAY_CLIENT_ID	Needs a value NOT SET

+ Add secret | Apply | Unsaved changes

🟢 invoice-processing promoted to production

Protected by BitSwan Bailey | tomas.novak@meridianfoods.cz | Share | Logout

Adding a stage secret — key + value, never committed to source



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.24

Use of cryptography & secret management.

Secrets are stored and injected securely, separated from source.

NIS2

ART. 21(2)(H)

Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.

GDPR

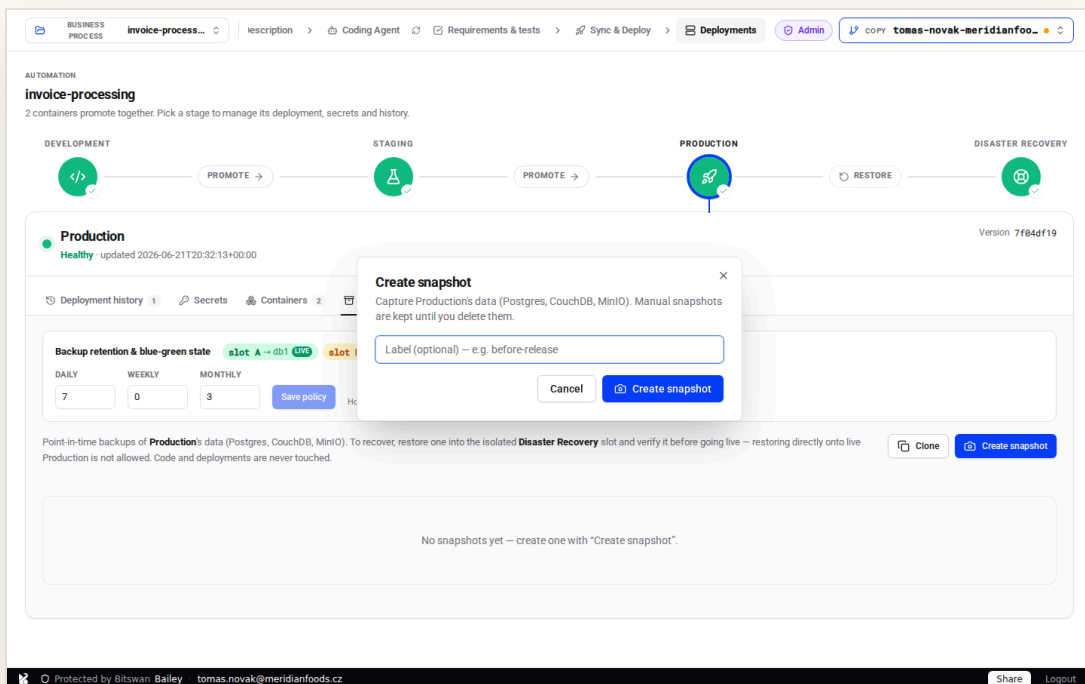
ART. 32

Security of processing. Credentials that protect personal data are kept out of source and role-gated.



Backups & retention

Point-in-time snapshots of the live database and object storage, with a retention policy and an audit trail.



Create snapshot · label and stage, before it runs

The **Create snapshot** dialog lets you label a snapshot and pick its stage; confirm and a task captures the **live blue-green database** — not a stale name — plus object storage, streaming its progress per store (Postgres, CouchDB, MinIO) so it never goes dark.

The result is a snapshot you can see, size, restore and clone between stages. Retention is a policy, not a cron job someone half-remembers.

HOW TO

- 1 Open **Production** → **Backups**.
- 2 Press **Create snapshot**; label it.
- 3 Watch it run; it lists with size and contents.

4 Set the retention policy.

The screenshot shows the BitSwan Bailey interface for the 'invoice-processing' application. The 'Backups' tab is selected, showing a 'Backup retention & blue-green state' section. The table below shows the backup configuration:

Backup retention & blue-green state	slot A → db1 (live)	slot B → db2 (db2)	slot C → idle
DAILY	7	0	3

The 'Save policy' button is visible. Below the table, there is a progress bar for 'Creating snapshot - Production' at 0% completion. The footer shows the user 'tomas.novak@meridianfoods.cz' and a 'Share' button.

Production · snapshot captured from the live DB



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.13

Information backup. Backups are taken, retained and verifiable by restoration.

DORA
ART. 12(1)

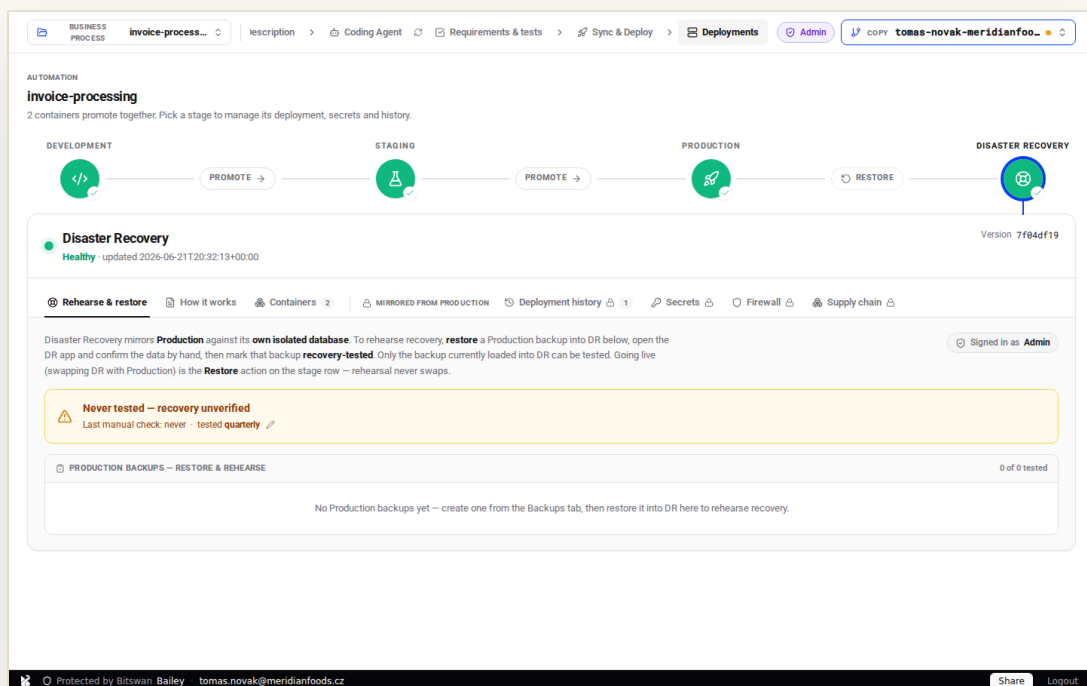
Backup policies and procedures. Scope and frequency are defined and enforced.

SOC 2
A1.2

Backup. Snapshots of live data are taken on demand and on policy.

Rehearse & restore (DR)

A backup you've never restored is a rumor. Bitswan makes the rehearsal a routine, the architecture legible, and the real cutover a single click.



Disaster Recovery · backup loaded into DR, recovery-tested

Restore a production backup **into the DR slot** — never onto live production. The restore streams its progress per store; when it lands, the slot is marked *In DR now*. Open it, confirm it's whole, and only the backup actually loaded into DR can be **marked recovery-tested**. The *How it works* tab explains the blue-green slots and the cutover in plain terms.

When you must go live, the **Restore** pill performs an ingress cutover — *Make Disaster Recovery the live Production?* — and -production repoints to the verified slot. No data migration, no redeploy, no downtime. (In a rehearsal you open that dialog to see it, then cancel.)

HOW TO

- 1 Take a production snapshot (Ch 14).
- 2 Go to **Disaster Recovery** → **Rehearse & restore**.
- 3 **Restore into DR**, verify, **Mark recovery-tested**.
- 4 Use the **Restore** pill to swap live when needed.

0 s

downtime on a swap

Quarterly

default test cadence

Verified

test only what's loaded

The screenshot shows the BitSwan Bailey automation interface for an 'invoice-processing' application. The workflow consists of four stages: Development, Staging, Production, and Disaster Recovery. The Disaster Recovery stage is currently active and healthy. The 'Right now' section shows the current state of the application slots: Slot A is serving database 1 in Production, Slot B is serving database 2 in Disaster Recovery, and Slot C is not serving any containers. The 'What this is for' section explains that the setup allows for switching between Production and Disaster Recovery without downtime, ensuring that the live environment is always backed up and can be restored if needed.

Disaster Recovery · how the blue-green slots and swap work



Bailey is best practice — what the standards ask of you, and how this does it

DORA

ART. 11–12

Response, recovery & restoration testing.

You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.

SOC 2

A1.2 / A1.3

Backup & recovery testing.

Restores are rehearsed into an isolated DR slot and the test is recorded.

ISO/IEC 27001

A.5.30 / A.8.13

ICT readiness for continuity.

Backups are verified by restoration into an isolated slot.

NIS2

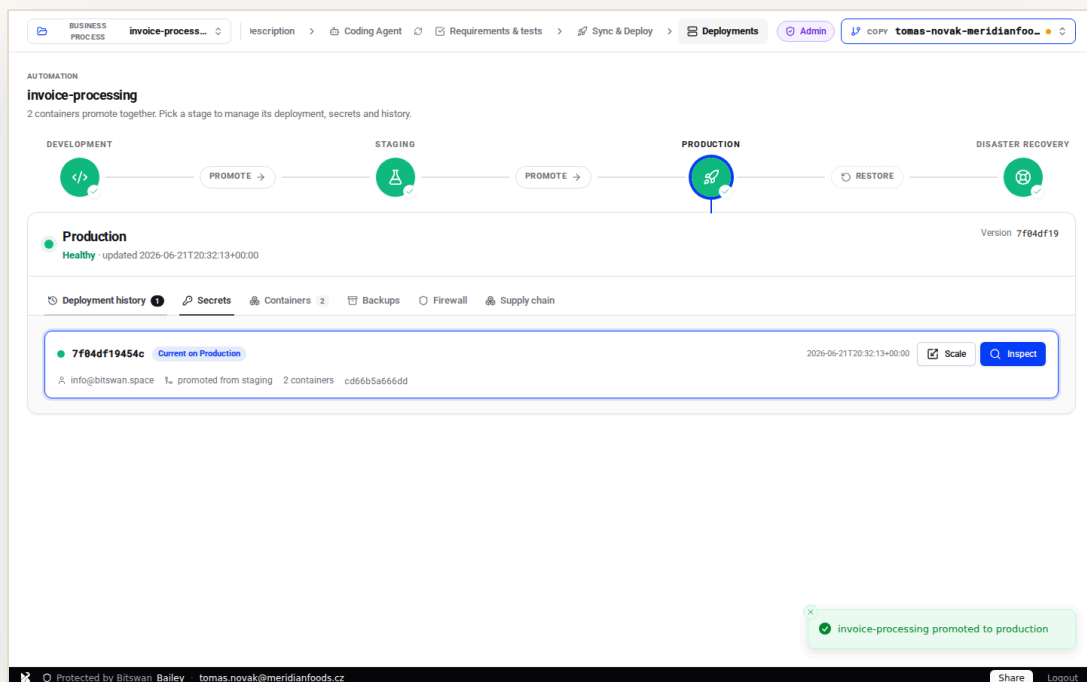
ART. 21(2)(C)

Business continuity & crisis management.

A zero-downtime swap means recovery doesn't cost an outage.

Deployment history & inspect

A versioned, immutable audit log: every deploy, promotion, swap, backup and firewall change — and a per-deployment Inspect with the files, diff and secrets in force at the time.



Deployment history · the audit trail of every event

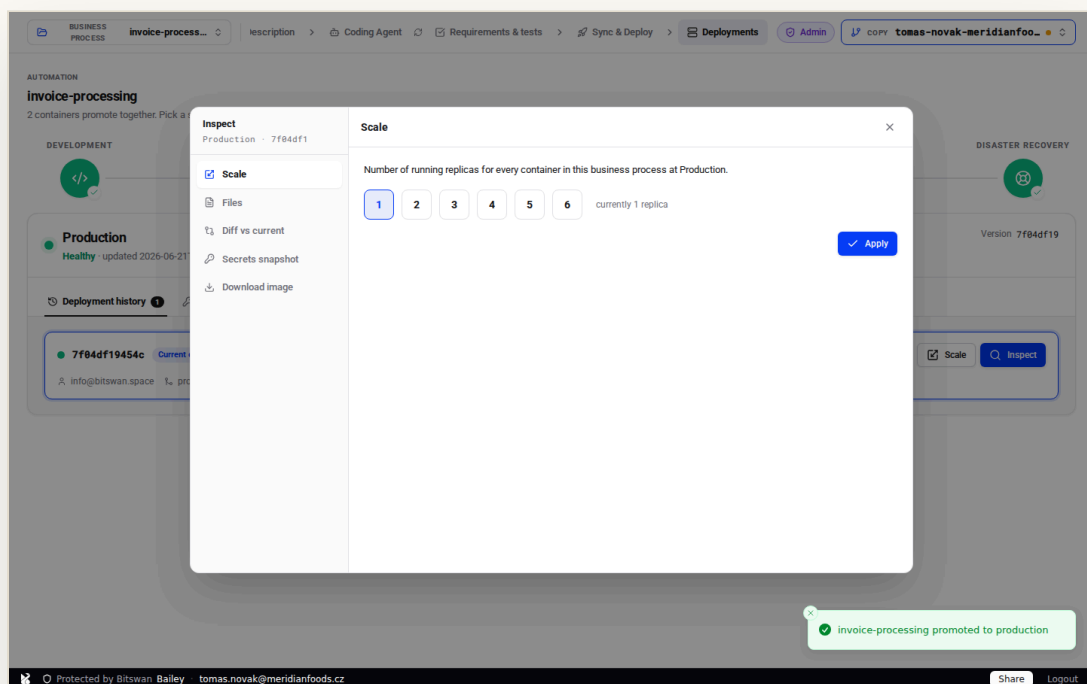
Who shipped what, when, on which commit, and what changed — including backup, restore, swap and retention events. The history is derived from the versioned record, so it can't be quietly edited. Each entry is a rollback point.

Open **Inspect** on any deployment and you get the receipts: the exact

files, the diff versus what's current, the **secrets snapshot** it ran with, and a download of the image. When an auditor asks “show me”, you open a tab.

HOW TO

- 1 Open a stage → **Deployment history**.
- 2 Read the timeline of events.
- 3 Press **Inspect** on an entry for files, diff and secrets.
- 4 Roll back to any entry if you must.



Inspect a deployment · files, diff vs current, secrets snapshot, image



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.15

Logging. Operational events are recorded and protected from tampering.

DORA
ART. 13

Learning and evolving. A complete record supports post-incident review.

NIS2
ART. 21(2)(B)

Incident handling. Reconstruct exactly what happened from the audit trail.

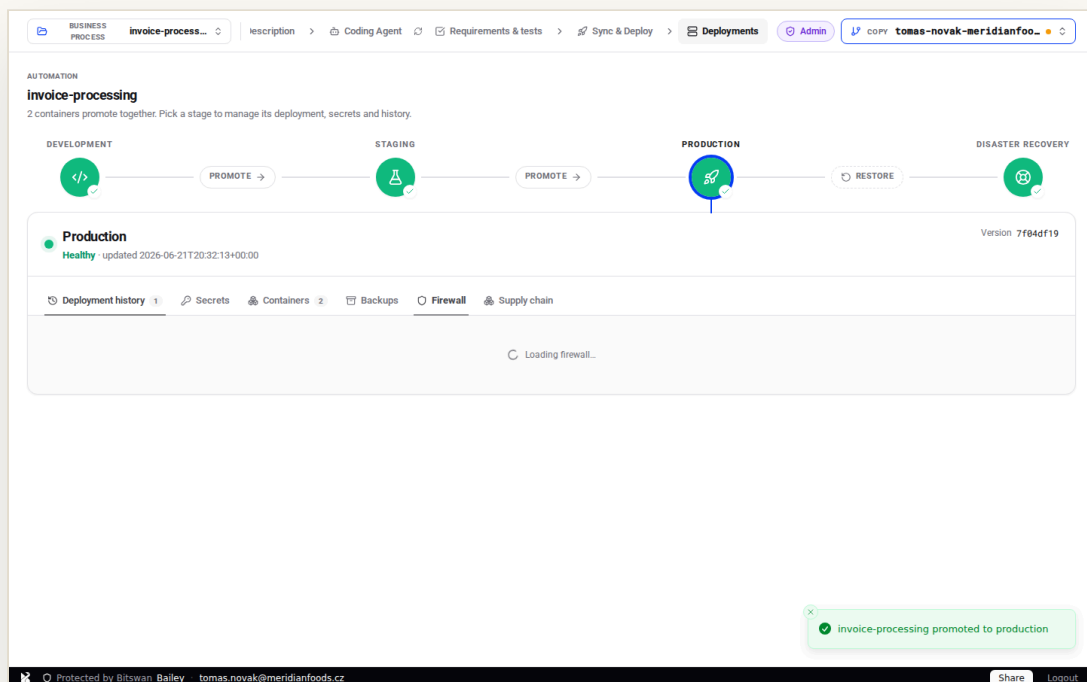
SOC 2
CC8.1

Change management. Every change is recorded with its diff and the config in force.



Firewall & data processing

An egress allow-list with a GDPR data-processing record for every external host — approval workflow, versioning and the DPA on file.



Firewall · the egress allow-list with its GDPR data-processing records

Meridian's invoice flow may reach its vendor portals, the Czech business register and a payment gateway — and nothing else. Egress is **default-deny**. Each allowed host carries a **GDPR data-processing record**: the purpose, whether personal data flows to that recipient, the lawful basis, and

the signed **Data Processing Agreement** on file.

A new destination can't go live until someone completes its processing record — so your Article 30 register builds itself as the system is operated, instead of being reconstructed under audit pressure.

HOW TO

- 1 Open a stage → **Firewall**.
- 2 Review hosts waiting for approval.
- 3 Complete the **GDPR data-processing record** (purpose, personal data, lawful basis).
- 4 Attach the processor's **DPA** and approve — the host is recorded and allowed.

GDPR, BY CONSTRUCTION

Every external recipient of data is recorded with its purpose and contract at the moment it's allowed. The record of processing activities (Art. 30) and the processor agreements (Art. 28) are a by-product of running the system — not a spreadsheet someone keeps separately.



Bailey is best practice — what the standards ask of you, and how this does it

GDPR
ART. 30

Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.

GDPR
ART. 28

Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.

NIS2
ART. 21(2)(A)

Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.

ISO/IEC 27001
A.8.20–8.21

Network & network-service security. Outbound connections are controlled per service.



People & roles

A roster with explicit roles — operator, auditor, member — and per-person trusted devices you can approve or revoke.

bailey-onboard.bs-e2...
Bailey Server

WORKSPACE

- Workspaces
- Handbook

YOUR ACCOUNT

- Your devices
- Security & recovery

ADMIN

- Server overview
- People & roles**
- Endpoint access

People & roles

Everyone with access to this server. Roles govern what they can do; devices govern where they can do it from. New sign-ins from an untrusted device appear here for you to approve.

☐ Least-trust access: a role grants *capabilities*, never blanket data access. Even an admin only reaches workspaces they created or were granted — so each person controls who sees their own data.

ADMIN Manages users, server settings, and device approvals. Still sees only workspaces they own or were granted — not everyone's.

AUDITOR Reviews security activity and signs off on deploy promotions. No automatic access to others' workspace data.

MEMBER Builds in workspaces they own or were added to.

USER A signed-in identity with no elevated role; sees only workspaces they own or are added to.

Search people...

PERSON	ROLE	WORKSPACES	DEVICES	LAST ACTIVE
tomas.novak@meridianfoods.cz tomas.novak@meridianfoods.cz	ADMIN	0	1	6/21/2026, 8:28:43 PM

Workspace "meridian-foods" created

People & roles · the Meridian Foods roster

Tomáš operates, Eva audits (read-only oversight, sets the recovery cadence), Marek and the team build. Roles are enforced server-side, not just hidden in the UI. This is also where pending devices are approved and lost ones revoked.

Each person's devices are visible; approve a new laptop, revoke a lost one — instantly, everywhere.

HOW TO

- 1 Open **People & roles** in the console.
- 2 Review roles across the team.
- 3 Approve a pending device by its code.
- 4 Revoke a device or change a role as people join and leave.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.5.18 / A.5.3

Access rights & segregation of duties.

Operator, auditor and member are distinct roles with least privilege.

SOC 2
CC6.2 / CC6.3

Access provisioning & de-provisioning.

Roles and per-person trusted devices are granted and revoked centrally.

NIS2
ART. 21(2)(I)

Human-resources security & access control.

Access is role-based and reviewable.

DORA
ART. 9(4)

Access management on a need-to-know basis. Auditors get oversight without write power.

Standards → features

One page for your auditor: the controls ISO 27001, SOC 2, DORA, NIS2 and GDPR ask for, and the Bitswan feature that delivers each.

STANDARD & CLAUSE	WHAT IT ASKS OF YOU	DELIVERED BY
NIS2 Art. 21(2)(j)	Multi-factor authentication & secured access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.	Claim & device trust
SOC 2 CC6.1	Logical access security. The gate authenticates and authorizes every request before it reaches a workspace app.	Claim & device trust
ISO/IEC 27001 A.5.15 / A.8.5	Access control & secure authentication. Access is granted per identity and per device, and centrally revocable.	Claim & device trust
DORA Art. 9(3)	Strong authentication mechanisms. Protection of ICT systems requires robust access control — the gate provides it uniformly.	Claim & device trust
ISO/IEC 27001 A.8.3 / A.5.15	Information access restriction & access control. A workspace scopes who can reach its processes and data; access is granted per workspace.	Workspaces

SOC 2 CC6.3	Role-based access. Membership and roles are assigned per workspace and enforced server-side.	Workspaces
NIS2 Art. 21(2)(i)	Asset management & access control. Every workspace and its endpoints are inventoried and owned.	Workspaces
ISO/IEC 27001 A.5.9	Inventory of information and other associated assets. Every workspace and protected endpoint is enumerated from real, live state.	Server overview & endpoints
NIS2 Art. 21(2)(i)	Asset management. The estate of exposed services is inventoried with ownership.	Server overview & endpoints
SOC 2 CC6.1	Logical access security. Each endpoint sits behind the gate with an explicit owner.	Server overview & endpoints
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Devices are granted and revoked centrally and immediately.	Your devices
ISO/IEC 27001 A.5.15 / A.8.1	Access control & user-endpoint devices. Trusted devices are enrolled, labelled and revocable.	Your devices
NIS2 Art. 21(2)(j)	Secured access. Hardware-bound trust is enrolled and managed per person.	Your devices
ISO/IEC 27001 A.8.31	Separation of development, test and production. A personal copy isolates work-in-progress from main and from deployed stages.	The workspace & copies
SOC 2 CC8.1	Change management. Changes originate in an isolated copy and reach main only through Sync & Deploy.	The workspace & copies

ISO/IEC 27001 A.5.9	Inventory of assets. Each business process is a named, owned unit of the estate.	Business processes
ISO/IEC 27001 A.8.25	Secure development lifecycle. Work is organised per process, with its own pipeline and controls.	Business processes
ISO/IEC 27001 A.5.37	Documented operating procedures. The process and its rules are written down and kept current alongside the code.	Describe the process
ISO/IEC 27001 A.8.25 / A.8.31	Secure development lifecycle & environment separation. The agent builds in an isolated copy/sandbox, never touching production directly.	Coding Agent & requirements
NIS2 Art. 21(2) (e)	Security in development. Agent output is CVE-scanned and reviewed before deploy.	Coding Agent & requirements
SOC 2 CC6.6	Boundary protection. The agent's egress is constrained by the workspace firewall allow-list.	Coding Agent & requirements
DORA Art. 24–26	Resilience testing. Requirements are runnable specifications, re-run on demand.	Coding Agent & requirements
ISO/IEC 27001 A.8.8	Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.	Sync & Deploy
NIS2 Art. 21(2) (e)	Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.	Sync & Deploy
DORA Art. 8–9	ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.	Sync & Deploy

SOC 2 CC8.1	Change management. Commit, rebase, deploy is one controlled, observable operation.	Sync & Deploy
NIS2 Art. 21(2) (d)	Supply-chain security. You can produce, on demand, exactly what is inside what you run.	Supply chain
SOC 2 CC7.1	Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.	Supply chain
ISO/IEC 27001 A.5.7 / A.8.8	Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.	Supply chain
ISO/IEC 27001 A.8.32	Change management. Production changes follow a controlled, reversible promotion path.	Blue-green production
ISO/IEC 27001 A.8.31	Separation of development, test and production. The dev / staging / production stages keep environments cleanly separated within a process.	Blue-green production
DORA Art. 9	Protection & prevention. Minimise the impact of changes on the availability of critical functions.	Blue-green production
SOC 2 CC7.2	System monitoring. Container health is visible per service, per stage.	Containers
DORA Art. 10	Detection. Operators can observe the live state of every running service.	Containers
ISO/IEC 27001 A.8.16	Monitoring activities. The running estate is observable in real time.	Containers

ISO/IEC 27001 A.8.24	Use of cryptography & secret management. Secrets are stored and injected securely, separated from source.	Secrets
NIS2 Art. 21(2) (h)	Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.	Secrets
GDPR Art. 32	Security of processing. Credentials that protect personal data are kept out of source and role-gated.	Secrets
ISO/IEC 27001 A.8.13	Information backup. Backups are taken, retained and verifiable by restoration.	Backups & retention
DORA Art. 12(1)	Backup policies and procedures. Scope and frequency are defined and enforced.	Backups & retention
SOC 2 A1.2	Backup. Snapshots of live data are taken on demand and on policy.	Backups & retention
DORA Art. 11–12	Response, recovery & restoration testing. You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.	Rehearse & restore (DR)
SOC 2 A1.2 / A1.3	Backup & recovery testing. Restores are rehearsed into an isolated DR slot and the test is recorded.	Rehearse & restore (DR)
ISO/IEC 27001 A.5.30 / A.8.13	ICT readiness for continuity. Backups are verified by restoration into an isolated slot.	Rehearse & restore (DR)
NIS2 Art. 21(2) (c)	Business continuity & crisis management. A zero-downtime swap means recovery doesn't cost an outage.	Rehearse & restore (DR)

ISO/IEC 27001 A.8.15	Logging. Operational events are recorded and protected from tampering.	Deployment history & inspect
DORA Art. 13	Learning and evolving. A complete record supports post-incident review.	Deployment history & inspect
NIS2 Art. 21(2) (b)	Incident handling. Reconstruct exactly what happened from the audit trail.	Deployment history & inspect
SOC 2 CC8.1	Change management. Every change is recorded with its diff and the config in force.	Deployment history & inspect
GDPR Art. 30	Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.	Firewall & data processing
GDPR Art. 28	Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.	Firewall & data processing
NIS2 Art. 21(2) (a)	Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.	Firewall & data processing
ISO/IEC 27001 A.8.20–8.21	Network & network-service security. Outbound connections are controlled per service.	Firewall & data processing
ISO/IEC 27001 A.5.18 / A.5.3	Access rights & segregation of duties. Operator, auditor and member are distinct roles with least privilege.	People & roles

SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Roles and per-person trusted devices are granted and revoked centrally.	People & roles
NIS2 Art. 21(2) (i)	Human-resources security & access control. Access is role-based and reviewable.	People & roles
DORA Art. 9(4)	Access management on a need-to-know basis. Auditors get oversight without write power.	People & roles

TECHNICAL-CONTROLS GUIDE

What Bailey gives you — at a glance

For each standard, how many technical controls Bailey provides outright, supports in part, or leaves to you to operate. The pages that follow break each down control-by-control, with a pointer to the chapter that shows it working.

ISO/IEC 27001:2022	11 PROVIDED	2 PARTIAL	0 YOUR PART
SOC 2 (Trust Services Criteria)	8 PROVIDED	1 PARTIAL	0 YOUR PART
DORA (Regulation (EU) 2022/2554)	6 PROVIDED	2 PARTIAL	0 YOUR PART
NIS2 (Directive (EU) 2022/2555)	6 PROVIDED	2 PARTIAL	0 YOUR PART
GDPR (Regulation (EU) 2016/679)	4 PROVIDED	1 PARTIAL	0 YOUR PART

✓ **Provided**

delivered by the platform

▸ **Partial**

platform supports it; you complete it

○ **Your part**

your organization operates it

TECHNICAL-CONTROLS GUIDE

ISO/IEC 27001:2022

Annex A technical controls. Bailey implements the platform-side controls below; the management-system controls (policies, risk assessment, HR, physical) remain yours.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
A.5.9	Inventory of assets	✓ Provided	Workspaces, endpoints and processes enumerated from live state	Asset classification policy	03 · 06
A.5.15 / A.8.5	Access control & secure authentication	✓ Provided	Device-trust gate + OIDC at the platform edge	Your IdP, joiner/leaver process	01 · 04
A.5.18	Access rights (least privilege, review)	✓ Provided	Operator / auditor / member roles, server-enforced	Periodic access reviews	18
A.8.8	Management of technical vulnerabilities	✓ Provided	Pre-deploy CVE scan + in-tree waivers	Triage & remediation SLAs	09 · 10
A.8.9	Configuration management	► Partial	bitswan.yaml as declarative source of truth	Baseline definition & review	11

A.8.13	Information backup	✓ Provided	Per-stage snapshots + retention policy	Offsite copy & retention targets	14
A.8.15 / A.8.16	Logging & monitoring	▸ Partial	Versioned deployment & event history; live container health	SIEM aggregation, alerting	12 · 16
A.8.20 / A.8.21	Network & network-services security	✓ Provided	Default-deny egress allow-list per service	Perimeter & internal segmentation policy	17
A.8.24	Use of cryptography & secrets	✓ Provided	Stage secrets, injected not committed; TLS at edge	Key-management policy	13
A.8.31	Separation of dev/test/production	✓ Provided	Isolated copies + dev / staging / production stages	—	05 · 11
A.8.3	Information access restriction	✓ Provided	Workspaces scope access per tenancy + role	Membership reviews	02
A.8.32	Change management	✓ Provided	Reversible blue-green promotion path + immutable history	Change approval workflow	11 · 16

A.5.30	ICT readiness for business continuity	✓ Provided	DR slot + rehearsed, recorded recovery tests	BCP/DR plan & RTO/RPO targets	15
---------------	---	-------------------	---	-------------------------------------	-----------

TECHNICAL-CONTROLS GUIDE

SOC 2 (Trust Services Criteria)

The common-criteria and availability TSCs Bailey supports as a service component. Your audit still covers the organizational criteria (CC1–CC5), risk assessment and vendor management.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
CC6.1	Logical access security	✓ Provided	Device-trust gate fronting every endpoint	Access policy & ownership	01 · 03
CC6.2 / CC6.3	Access provisioning & removal	✓ Provided	Central role + device grant/revoke	Timely de-provisioning process	04 · 18
CC6.6	Boundary protection	✓ Provided	Default-deny egress allow-list	Network perimeter design	17
CC6.7	Data in transit & at rest	✓ Provided	TLS at the edge (traefik) with managed cert lifecycle; backups encrypted	Disk encryption on the Bailey host (at rest)	01 · 14
CC7.1	Vulnerability detection	✓ Provided	SBOM + CVE scan on the image that ships	Remediation tracking	10
CC7.2	System monitoring	▸ Partial	Container health + event history	Alerting & on-call	12 · 16

CC8.1	Change management	✓ Provided	Promotion pipeline + immutable deploy history	Change authorization	09 · 11 · 16
A1.2	Backup & environmental protection	✓ Provided	Snapshots + standby DR slot	Backup off-platform	14 · 15
A1.3	Recovery testing	✓ Provided	Rehearse-into-DR + recorded recovery tests	Test cadence sign-off	15

TECHNICAL-CONTROLS GUIDE

DORA (Regulation (EU) 2022/2554)

The ICT risk-management articles Bailey operationalizes for financial entities. Governance, incident reporting to authorities, and third-party registers remain your obligation.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 8	Identification of ICT risk	✓ Provided	Pre-deploy supply-chain / CVE identification	Risk register & classification	10
Art. 9(3)	Strong authentication & protection	✓ Provided	Device-trust gate	Identity governance	01
Art. 9	Protection & prevention (change impact)	✓ Provided	Zero-downtime blue-green change path	Segregation policy	11
Art. 10	Detection of anomalous activity	▸ Partial	Container health + deployment/event history	Detection thresholds & alerting	12 • 16
Art. 11	Response & recovery	✓ Provided	One-cutover DR swap, no data move	Crisis-management plan	15
Art. 12	Backup, restoration & testing	✓ Provided	Snapshots + rehearsed DR restores	RTO/RPO & offsite policy	14 • 15
Art. 13	Learning & evolving	✓ Provided	Complete, inspectable deploy audit trail	Post-incident review process	16

Art. 24–26

Resilience
testing
programme

Partial

Runnable
requirement tests
+ DR rehearsals

TLPT for
significant
entities

08 · 15



BitSwan Bailey · The Operator's Handbook

DORA (Regulation (EU) 2022/2554)

TECHNICAL-CONTROLS GUIDE

NIS2 (Directive (EU) 2022/2555)

The Article 21(2) cybersecurity-risk-management measures Bailey delivers technically. Governance, training and incident notification to your CSIRT stay with you.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 21(2)(a)	Risk analysis & network security	▸ Partial	Default-deny egress with reviewed exceptions	Risk-analysis methodology	17
Art. 21(2)(b)	Incident handling	▸ Partial	Reconstruct events from the audit trail	Incident response & notification	16
Art. 21(2)(c)	Business continuity & backups	✓ Provided	Backups + zero-downtime DR swap	BCP & crisis comms	14 · 15
Art. 21(2)(d)	Supply-chain security	✓ Provided	SBOM + CVE visibility per image	Supplier assessment	10
Art. 21(2)(e)	Secure development & vuln handling	✓ Provided	Pre-deploy checks + versioned waivers	SDLC policy	09
Art. 21(2)(h)	Cryptography	✓ Provided	Secret handling + TLS at the edge	Crypto policy	13

Art. 21(2)(i)	Access control & asset management	✓ Provided	Roles + workspace/endpoint inventory	Asset ownership	02 · 03 · 18
Art. 21(2)(j)	Multi-factor authentication	✓ Provided	Hardware-bound device trust	Enrolment policy	01 · 04

TECHNICAL-CONTROLS GUIDE

GDPR (Regulation (EU) 2016/679)

The security-of-processing and accountability articles Bailey supports. Lawful basis, data-subject rights, DPIAs and breach notification remain controller obligations.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 30	Records of processing activities	✓ Provided	Per-egress data-processing record, auto-maintained	Controller-level register	17
Art. 28	Processor obligations / DPAs	✓ Provided	DPA stored before egress is allowed	Contract terms & due diligence	17
Art. 32	Security of processing	✓ Provided	Access control, secrets, backup & resilience	Risk-based measures & review	13 · 14 · 15
Art. 5(1)(f)	Integrity & confidentiality	✓ Provided	Gated access + default-deny egress	Data-handling policy	01 · 17
Art. 33	Breach notification	► Partial	Audit trail to reconstruct what happened	72-hour notification process	16

